접근권한 정기점검 및 회수 절차

문서번호	GW-SEC-077	시행일	2026.10.01
작성·관리	정보보안팀	문서판	1.0

1. 점검 준비

1.1 대상과 주기

정보보안팀은 주요 업무시스템·개인정보처리시스템·공유 저장소의 권한 목록을 분기별로 점검한다. 고위험 특권계정은 월별 모니터링 또는 위험에 따른 강화 주기를 적용한다.

1.2 목록 수집

IT지원팀과 시스템 관리자는 계정별 소속, 권한 역할, 마지막 사용시각, 승인근거, 유효기간을 추출한다. 점검 문서에는 비밀번호·인증토큰을 포함하지 않는다.

1.3 대조 기준

인사팀의 입퇴사·휴직·부서이동 목록, 계약 종료 명단, 시스템 소유자의 사용자 목록과 실제 기술적 권한을 대조한다.

2. 승인·조치

2.1 소유부서 검토

시스템 소유자는 부서별 사용자와 업무상 필요 권한을 확인하고 유지·회수·기한 변경을 명시한다. 직함이 높거나 과거에 권한을 사용했다는 사유만으로 유지 처리하지 않는다.

2.2 회수

회수 대상은 IT지원팀이 적용하고 권한 반영 시각과 실행 결과를 점검표에 남긴다. 퇴사 계정 등 긴급 대상을 일반 정기점검 시점까지 방치하지 않는다.

2.3 예외

권한 유지가 필요한 예외는 업무목적·대체통제·만료일·승인자를 적고 SEC-080에 따라 처리한다. 서명만 된 빈 점검표나 승인 미완료 항목을 종결로 표시할 수 없다.

2.4 실패 처리

권한 회수 명령이 실패했거나 외부 SaaS 연동 결과가 불확실하면 재처리·담당자 지정·임시 차단 조치를 기록한다.

3. 결과 검증

3.1 재조회

점검 조치 후 실제 서비스에서 권한을 재조회해 의도한 대상에 반영되었는지 확인한다. 신청서의 승인 상태만으로 결과를 추정하지 않는다.

3.2 이력 보존

개인정보처리시스템의 권한 부여·변경·말소 내역은 관계 고시가 정한 보존 의무를 준수한다. 일반 업무 시스템도 회사 보존 정책에 따른 증적을 남긴다.

3.3 개선 조치

반복되는 미회수·과잉 부여 원인을 유형별로 분류하여 권한 신청 시스템과 조직 통보 절차를 개선한다.

업무 처리 기준 및 확인 사항

표 1. 정기점검 결과 분류

판정	의미	처리
유지	업무상 필요와 근거 일치	재검토 시점 기록
축소	일부 권한 과다	범위 변경 후 재조회
회수	업무 종료·인사 변경	권한 제거 및 검증
예외	한시적 필요	SEC-080 승인과 만료일
미확인	자료·반영 증거 부족	담당자 지정 후 재점검

별첨 / 서식

별첨 1. 접근권한 정기점검 결과표

점검 대상 시스템		점검 기준일	
계정·사용자 식별자		소속 / 고용상태	
현 권한		업무 필요성 확인	
판정(유지/축소/회수)		소관부서 승인	
IT 변경 처리 시각		재조회 결과	
예외 만료일		추가 조치 담당자	